

Threat Vectors

A method used by the attacker:

- Gain access or infect to the target
- Also called "Attack vectors"

A lot of work goes into finding vulnerabilities in these vectors:

- Some are more vulnerable than others.

IT security professionals spend their career watching these vectors

- Protect existing vectors
- Find new vectors

Message Based vectors:

- One of the biggest and most successful threat vectors:
- Everyone has at least one messaging system

Email:

- Malicious links in an email
- Link to malicious site

SMS (short message service):

- Attacks in a text message

Phishing attacks:

- People want to click links
- Links in an email, links sent via text or IM

Deliver the malware to the user:

- Attach it to the email
- Scan all attachments, never launch untrusted links

Social engineering attacks:

- Invoice scams
- Cryptocurrency scams

Image based vectors:

Easy to identify a text based threat;

- It's more difficult to identify the threat in an image

Some image formats can be a threat:

- The SVG (Scaleable vector graphic) format

Significant security concerns:

- HTML injection
- Javascript attack code

Browsers must provide input validation:

- Avoids running malicious code



```
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg PUBLIC "-//W3C//DTD SVG 1.1//EN" "http://www.w3.org/
Graphics/SVG/1.1/DTD/svg11.dtd">

<svg version="1.1" baseProfile="full" xmlns="http://www.w3.org/2000/
svg">
  <polygon id="triangle" points="0,0 0,50 50,0" fill="#009900"
stroke="#004400"/>
  <script type="text/javascript">
    alert("This is an XSS attack");
  </script>
</svg>
```



This is an example of an SVG:

- It runs the image which is the polygon but also runs simultaneously the script attack.

File based vectors:

More than just executables:

- Malicious code can hide in many places

Adobe PDF:

- A file format containing other objects

ZIP/RAR files (or any compression type):

- Contains many different files

Microsoft Office:

- Documents with macros
- Add-in files

Voice call vectors:

Vishing:

- Phishing over the phone

Spam over IP:

- Large scale phone calls

War dialing:

- it still happens

Call tampering:

- Disrupting voice calls

Removable device vectors:

Get around firewall:

- The USB drive

Malicious software:

- Infect air gapped networks
- Industrial systems, high security services

USB devices can act as keyboards:

- Hacker on a chip

Data exfiltration:

- Terabytes of data walk out the door
- Zero bandwidth used

Vulnerable software vectors:

Client based:

- Infected executable
- Known (or unknown) vulnerabilities
- May Require constant updates

Agentless:

- No installed executable
- Compromised software on the server would affect all users
- Client runs a new instance each time

Unsupported system vectors:

Patching is an important prevention tool:

- Ongoing security fixes

Unsupported systems aren't patched:

- There may not be an option

Outdated operating systems:

- Eventually, even manufacturer won't help

A single system could be an entry;

- Keep your inventory and records current

Unsecure network vectors:

- Ease of access for the attackers
- View all (non-encrypted) data

Wireless:

- Outdated security protocols (WEP, WPA, WPA2)
- Open rogue wireless networks

Wired;

- Unsecure interfaces - NO 802.1X

Bluetooth:

- Reconnaissance
- Implementation vulnerabilities

Open service ports:

Most network-based services connect over a TCP or UDP port:

- An “open” port

Every open port is an opportunity for the attacker:

- Application vulnerability or misconfiguration

Every application has their own open port:

- More services expand and the attack surface

Firewall rules:

- Must allow traffic through an open port

Default Credentials:

Most devices have default usernames and passwords:

- Change yours!

The right credentials provide full control:

- Admin access

Very easy to find the defaults for your access point or router:

- <https://www.routerpasswords.com>

Supply chain vectors:

Tamper with the underlying infrastructure:

- Or manufacturing process

Manages service providers(MSP):

- Access many different customer network from one location.

Gain access to a network using a vendor:

- 2013 Target credit card breach

Suppliers:

- Counterfeit networking equipment
- Install backdoors, substandard performance and availability
- 2020 - Fake cisco catalyst switches

Phishing:

Social engineering with a touch of spoofing:

- Often delivered by email, text, etc.
- Very remarkable when well done

Dont be fooled:

- Check the URL

Usually there something not quite right:

- Spelling, Fonts, graphics

Business email compromise:

We trust email sources:

- The attackers take advantage of this trust

Spoofed email addresses:

- Not really a legitimate email address
- professor@professormessor.com = spoofed because of misspelled

Financial fraud:

- Sneds emails with updated bank info
- Modify wire transfer details

The recipient clicks the link:

- The attachment has malware

Tricks and misdirection:

How are they so successful:

- Digital slight of hand
- It fools the best of us

Typo squatting;

andymullens2019@gmail.com - misspelled but cleverly placed

Pretexting:

- Lying to get info
- Attacker is a character in a situation they create
- Hi, were calling from visa regarding an automated payment to your utility service....

Vishing (voice phishing):

- Caller ID is pretending as someone they aren't

Smishing:

- SMS text messaging that is trying to pretend to be someone to get you to click a link.
- Also will ask for personal info

Variations on a theme:

- The fake check scam , phone verification scam code, Boss/CEO scam, advance-free scam

Impersonation:

The pretext:

Before the attack, the trap is set.

- This is basically the story they are trying to use to get you to do something.
- Like pretending to be the IRS, Microsoft or anyone that you may trust that will try to rush you to get your information.

Impersonation;

Callers that pretend to be someone they aren't:

- More directed attack than pretext
- Uses real information that you trust to get you to leak information to them
- Like pretending to be your workplaces help desk or IT, CEO etc.
- Normally will try to impersonate someone of higher rank at your company
- Will use technical jargon to confuse the victim
- Might try to get to know you or be your buddy

Elicit information:

- they want your info obviously
- Hacking you
- Vishing is a very common way they do this

These are well documented psychological attacks:

- They won't just ask what your password is they will try to lure the info out of you.

Identity fraud:

KEEP YOUR PERSONAL DATA SAFE:

Credit card fraud:

- Open account in your name or use your credit card

Bank fraud:

- Attacker gains access to you account or opens a new account

Loan fraud:

- Your information is used for a loan or lease

Government benefits fraud:

- Attacker obtains your benefits by using your personal info

How to protect:

Dont volunteer personal info

Dont disclose personal details

Always verify before revealing info

Verification should be encouraged.

Other Social Engineering attacks

Misinformation/disinformation:

Disseminate factually incorrect information:

- Create confusion and division

Influence campaigns:

- Sway public opinion on political and social issues

Nation state actors:

- Divide, distract, and persuade

Advertising is an option:

- Buy a voice for your opinion

Enabled through social media:

- Creating, sharing, liking and amplifying

The misinformation process:

Step 1: Create a ton of fake user

Step 2: Create content

Step 3: Post on social media

Step 4: Amplify message

Step 5: Real users share message

Step 6: Mass media picks up the content

Brand impression:

Pretend to be a well-known brand:

- Coca-cola etc.

Create tens of thousands of impersonated sites:

- Get into the google index, click an ad, get a WhatsApp message

Visitors are presented with a pop-up:

- You won! Special offer! Download the video now!

Malware infection is almost guaranteed:

- Display ads, site tracking, data exfil

